TECNOLOGÍA EN DESARROLLO DE SOFTWARE

PROYECTO ASISTENTEIA

AUDITORÍA CON API KEY REAL

Hallazgos, correcciones y verificación

Elaborado por	Juan Esteban Olaya Muñoz
Programa	Tecnología en Desarrollo de Software
Producto	Hallazgos, correcciones y verificación
Fecha	23/10/2026

Fecha: 23/10/2026. Proveedor: Google Gemini (endpoint compatible OpenAI). La clave se pasó por variable de entorno temporal; no está en el repositorio ni en estos documentos.

1. Alcance

- Flujo completo con servicios reales: detectar proveedor → listar modelos → validar → guardar → consultar → persistir en SQLite (tests/LiveKeyTests.cs).
- Llamadas REST directas para documentar códigos HTTP (docs/evidencias/rest_gemini_con_clave.txt).
- Revisión de código: manejo de errores, fugas de clave, catálogo de modelos.

2. Hallazgos

#	Hallazgo	Severidad	Estado
H-01	Con la clave real la UI mostró "Validación fallida: respuesta vacía": Gemini devuelve HTTP 200 sin content con max_tokens=1 (modelos con razonamiento).	Alta (bloqueaba el uso)	Corregido y probado
H-02	Modelo por defecto de Gemini (gemini-2.0-flash) retirado: HTTP 404.	Alta	Corregido: gemini-3.1-flash-lite
H-03	La lista de modelos de Gemini incluía modelos de imagen, audio y tts no aptos para chat.	Media	Corregido: filtro y prueba
H-04	La clave con formato AQ. no se detectaba automáticamente.	Baja	Corregido: detección AQ. (cae al selector si no coincide)
H-05	La clave de pruebas quedó expuesta fuera de la app durante la auditoría.	Alta (operativa)	Pendiente: revocar y regenerar la clave
H-06	Android: la app se cerraba al iniciar y Inicio mostraba "No se pudo leer el historial local": mezcla de paquetes SQLitePCLRaw 2.x y 3.x tras fijar solo la librería nativa.	Alta (bloqueaba Android)	Corregido: línea 3.x completa (bundle_e_sqlite3 3.0.5); verificado en un teléfono Android 15
H-07	Con una clave inválida Google responde 400 y el mensaje decía "revisa el modelo o el contenido".	Baja	Corregido: el mensaje incluye la clave
H-08	El flujo por la UI de Windows con la clave real no se reverificó tras el fix de validación.	Media (verificación)	Pendiente (el mismo flujo se verificó completo en Android)

3. Resultados verificados

- GET /models → 200 (60 modelos). Validación → 200. Consulta real → 200 con respuesta y 29 tokens de salida.
- Modelo inexistente o retirado → 404 mapeado a NotFound sin exponer la clave.
- La clave solo existe en ISecretStore: no aparece en ajustes ni en mensajes de error (aserciones en pruebas).
- Un prompt vacío no llega a la red aunque haya clave.
- Suite completa: 51 pruebas, 0 fallos; compilación Windows y Android sin errores.
- Teléfono Android 15 (API 35, arm64) por USB: detectar proveedor, validar, guardar clave, consulta real, guardar, detalle, actualizar, eliminar, persistencia tras cerrar la app, clave inválida y eliminar clave.

4. Recomendaciones

- Revocar la clave usada en esta auditoría y crear otra restringida (cuota y, si es posible, restricción de API).
- Mantener modelos como parámetro del usuario: los proveedores retiran modelos con frecuencia.